



移动智能终端生态联盟——金标认证标准 2.0

安全标准

编制单位：移动智能终端生态联盟·标准工作组

2024 年 8 月

目录

引言	4
前言	4
一、 适用范围.....	4
二、 规范性引用文件.....	5
三、 术语、定义和缩略语.....	5
3.1 术语和定义.....	5
3.1.1 Intent.....	5
3.1.2 热更新 hotfix.....	5
3.1.3 个人信息 personal information.....	5
3.1.4 个人敏感信息 personal sensitive information.....	5
3.1.5 敏感权限 sensitive permission.....	6
3.1.6 移动应用软件 mobile application.....	6
3.1.7 移动智能终端 smart mobile terminal.....	6
3.1.8 恶意应用 malicious application.....	6
3.1.9 安全键盘 secure keyboard.....	6
3.1.10 关联启动 associated startup.....	6
3.1.11 自启动 self-starting.....	6
3.1.12 反卸载.....	6
3.2 缩略语.....	6
四、 移动智能终端安全架构.....	7
五、 应用行为安全技术要求.....	7
5.1 应用安装.....	7
5.1.1 安装升级.....	7
5.1.2 恶意安装.....	8
5.2 应用运行.....	8
5.2.1 应用启动.....	8
5.2.2 应用权限.....	8
5.2.3 应用敏感操作.....	9
5.2.4 应用流氓行为.....	9
六、 应用开发安全技术要求.....	10
6.1 数据安全.....	10
6.1.1 机密性.....	10
6.1.2 完整性.....	11
6.2 编码安全.....	11
6.2.1 编码规范.....	11
6.2.2 审计加固.....	11
6.2.3 第三方 SDK 规范.....	12
6.2.4 应用权限规范.....	12
6.2.5 组件安全规范.....	12
6.2.6 工具链安全规范.....	13

6.3 业务安全.....	13
6.3.1 业务鉴权规范.....	13
6.3.2 安全策略规范.....	14
6.4 隐私保护规范.....	14
七、应用内容安全要求.....	14
7.1 基本要求.....	14
7.2 政治内容管理要求.....	15
7.3 暴恐血腥内容管理要求.....	15
7.4 违禁品内容管理要求.....	15
7.5 宗教、种族等内容管理要求.....	16
7.6 色情内容管理要求.....	16
7.7 赌博、彩票类内容管理要求.....	16
7.8 恶意扣费、欺诈内容管理要求.....	17
7.9 广告内容管理要求.....	17

引言

移动应用软件是移动智能终端安全架构中关键的要素之一，其种类和数量持续增长，全面影响着现代社会的方方面面，成为不可替代的公共基础设施。但因为恶意应用的安装和运行，对移动智能终端的操作系统安全性、稳定性和用户数据安全等产生了负面影响。在移动智能终端上通过安装安全可信的应用是抵御恶意应用的威胁的重要保障，也是在移动智能终端硬件和操作系统之间建立起信任链条的基础。

移动应用软件开发者和运营者依据《中华人民共和国网络安全法》、《中华人民共和国密码法》《电信和互联网用户个人信息保护规定》（工业和信息化部令第 24 号）、《移动智能终端应用软件预置和分发管理暂行规定》（工信部信管函〔2016〕407 号）、《关于开展 APP 侵害用户权益专项整治工作的通知》（工信部信管函〔2019〕337 号）、《关于开展纵深推进 APP 侵害用户权益专项整治行动的通知》（工信部信管函〔2020〕164 号）、《App 违法违规收集使用个人信息行为认定方法》等相关法律法规和规范性文件要求，本着提升产品和服务的，要将安全贯穿到产品设计、开发、运营管理全流程全环节。

本标准仅给出了移动应用软件应满足的安全技术要求，对其的具体技术实现方式、测试方法等不作规定。关于移动智能终端的硬件安全要求，可参见 GB/T 35278-2018 和 TAF-WG4-AS0015；操作系统软件安全性要求，可参见 GB/T 34976-2017；用户数据安全可参加 GB/T 34978-2017 和 GB/T 35273-2020。本标准中，凡涉及密码算法的相关内容，应符合法律、法规的规定和密码相关国家标准、行业标准的要求。

前言

本标准按照 GB/T1.1-2009 给出的规则起草。

本标准是移动智能终端生态联盟标准之一，本文件由移动智能终端生态联盟提出并归口。请注意本文件的某些内容可能涉及专利，本文件的发布机构不承担识别这些专利的责任。

一、 适用范围

本标准主要规定了基于安卓系统的移动智能终端上应用行为安全、应用开发安全和应用内容安全这三方面的安全性技术要求，其中应用行为安全包括了应用安装、应用运行的要求；应用开发安全包括了数据安全、编码安全、业务安全和隐私保护的要求；应用内容安全包括了基本要求、政治内容管理、暴恐血腥内容管理、违禁品内容管理、宗教种族等内容管理、色情内容管理、赌博彩票类内容管理、恶意扣费、欺诈内容管理和广告内容管理的要求。

本标准适用于从事安卓移动应用软件或平台服务的软件开发者和运营者，并为评估机构开展各类安卓应用的安全检查与评估工作提供参考。

二、规范性引用文件

下列文件对于本文件的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本文件。凡是不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 35273-2020 信息安全技术 个人信息安全规范

GB/T 37729-2019 信息技术 智能移动终端应用软件（APP）技术要求

GB/T 41391—2022 信息安全技术 移动互联网应用程序（App）收集个人信息基本要求

YD/T 2407—2021 移动智能终端安全能力技术要求

TAF-WG4-AS0051:2021 移动智能终端及应用软件用户个人信息保护实施指南 第5部分：终端权限管理

T/TAF 078.9-2020 APP 用户权益保护测评规范移动应用分发平台信息展示

移动智能终端生态联盟标准 第6部分：个人信息保护技术要求

三、术语、定义和缩略语

3.1 术语和定义

GB/T 35273-2020、GB/T 37729-2019 和 YD/T 2407-2021 界定的以及下列术语和定义适用于本标准。

3.1.1 Intent

是消息传递对象，用于从其他应用组件请求操作。

注1：可参见 <https://developer.android.com/guide/components/intents-filters?hl=zh-cn>。

3.1.2 热更新 hotfix

通过动态下发和加载代码，在 App 或 SDK 不重新下载和安装的情况下，改变其原有代码逻辑或资源文件。

3.1.3 个人信息 personal information

以电子或者其他方式记录的能够单独或者与其他信息结合识别特定自然人身份或者反映特定自然人活动情况的各种信息。

注1：个人信息包括姓名、出生日期、身份证件号码、个人生物识别信息、住址、通信通讯联系方式、通信记录和内容、账号密码、财产信息、征信信息、行踪轨迹、住宿信息、健康生理信息、交易信息等。

注2：关于个人信息的判定方法和类型可参见 GB/T 35273-2020 中附录 A。

3.1.4 个人敏感信息 personal sensitive information

一旦泄露、非法提供或滥用可能危害人身和财产安全，极易导致个人名誉、身心健康受到损害或歧视性待遇等的个人信息。

注1：个人敏感信息包括身份证件号码、个人生物识别信息、银行账号、通信记录和内容、财产信息、征信信息、行踪轨迹、住宿信息、健康生理信息、交易信息、14岁以下（含）儿童的个人信息等。

注2：关于个人敏感信息的判定方法和类型可参见 GB/T 35273-2020 中附录 B。

3.1.5 敏感权限 sensitive permission

敏感权限涵盖 App 需要涉及用户个人敏感信息的数据或资源的区域，或者可能会影响用户存储的数据或其他 App 的操作。例如，读取设备识别码（IMEI、WLAN、MAC 地址等）的权限是一种敏感权限。

注 1：敏感权限类别可参见 TAF-WG4-AS0051:2021 的 3.2 和 3.3。

3.1.6 移动应用软件 mobile application

针对移动智能终端所开发的应用程序，包括移动智能终端预置应用软件以及互联网信息服务提供者提供的可以通过智能终端下载、安装、升级、卸载的应用软件。

前台：用户可见的当前界面。

3.1.7 移动智能终端 smart mobile terminal

设备能够接入通信网，有可供应用程序软件运行的操作系统，并能让用户安装、运行和卸载 App 的计算机产品。

注 1：见 [GB/T 37729-2019，定义 3.1.2]

3.1.8 恶意应用 malicious application

是指含有信息窃取、恶意扣费、诱骗欺诈、系统破坏等恶意行为及其他危害用户权益和网络安全的 App。App 的恶意行为，包括但不限于恶意扣费、信息窃取、远程控制、恶意传播、资费消耗、系统破坏、诱骗欺诈、流氓行为。

注 1：恶意行为的详细定义见 GB/T 37729-2019 的 4.7.2。

3.1.9 安全键盘 secure keyboard

在应用中输入密码时，为用户提供键盘乱序、输入不记录、键盘防监听等方面安全防护能力的键盘。

3.1.10 关联启动 associated startup

指在用户没有直接操作某个移动应用软件的情况下，移动应用软件采用 Activity 组件、Service 组件、Provider 组件或 Broadcast 组件的方式启动其他移动应用软件进程的行为。

3.1.11 自启动 self-starting

指在用户没有直接操作某个移动应用软件的情况下，该软件通过包括但不限于系统的广播、定时任务、账号同步、粘性服务、通知使用权等机制启动该软件的行为。

3.1.12 反卸载

反卸载或假卸载操作的方式包括但不限于隐藏图标、移除图标、自我复制程序、修改应用名称、在主屏幕界面有图标的快捷方式、小程序、快应用不可被移除。

3.2 缩略语

下列缩略语适用于本标准。

App：移动互联网应用程序（Application）

Android：安卓（Android）

CNNVD：中国国家信息安全漏洞库（China National Vulnerability Database of Information Security）

CNNVE：中国通用漏洞披露（China National Vulnerability Database of Information Security）

CNVD：国家信息安全漏洞共享平台（China National Vulnerability Database）

CVE: 通用漏洞披露 (Common Vulnerabilities and Exposures)
HMAC: 哈希运算消息认证码 (Hash-based Message Authentication Code)
SDK: 软件开发工具包 (Software Development Kit)

四、移动智能终端安全架构

基于 Android 操作系统的移动智能终端安全架构包括了硬件安全、系统软件安全、App 安全、接口安全、用户数据安全组成，其架构如下图 1 所示，详见参考文献[1]GB/T 32927—2016。

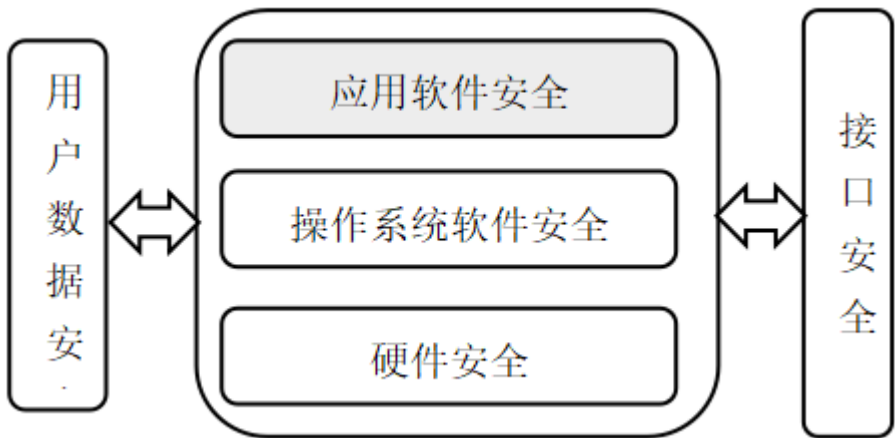


图 1 移动智能终端的安全架构

本标准仅给出了 App 应满足的安全性技术要求，对 App 的具体技术实现方式、测试方法等不作规定。关于移动智能终端的硬件安全性要求，可参见[2]GB/T 35278-2018 和[3]TAF-WG4-AS0015-V1.0.0 2018；操作系统软件安全性要求，可参见[4]GB/T 34976-2017 和[5]GB/T 30284-2020；用户数据安全可参见[6]GB/T 34978-2017 和 GB/T 35273-2020。

五、应用行为安全技术要求

5.1 应用安装

5.1.1 安装升级

表 1 应用安装升级行为要求

标准描述	应用安装升级行为要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 授权：应用的下载、安装、升级必须获得用户授权。 - 快捷方式：未经用户授权，禁止应用在桌面自动添加多个快捷方式图标。

	- 强制升级：除非出现 CNVD、CNNVD、CVE、CNCVE 等公开发布了 6 个月及以上的高危安全漏洞，否则禁止通过关闭服务的方式强制引导用户升级应用。 - 升级方式：推荐通过应用市场升级应用，不推荐应用内部实现自动更新、热更新等风险机制。涉及个人信息处理规则变更（即隐私政策中内容变化或新增敏感权限需要重新获得用户的授权同意）、基本功能变更的应提示用户并在用户同意后进行更新。
需考虑的特殊事项	

5.1.2 恶意安装

表 2 应用安装行为要求

标准描述	应用安装行为要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 恶意诱导：禁止诱导、欺骗、恐吓、威胁用户下载安装其他应用。 - 恶意模块：禁止安装包含欺诈、病毒、木马、后门等恶意模块的应用。 - 漏洞模块：禁止安装包含国家信息安全漏洞共享平台（CNVD）、中国国家信息安全漏洞库（CNNVD）、CVE、CNCVE 等公开发布了 6 个月及以上的高危安全漏洞的模块的应用。
需考虑的特殊事项	

5.2 应用运行

5.2.1 应用启动

表 3 应用启动行为要求

标准描述	应用启动行为要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 后台自启动：如果没有相关功能需求，不推荐应用在后台自启动。 - 流氓启动：禁止应用程序在首次启动时，要求用户进行敏感权限授权、或者执行指定任务，否则应用强制退出。
需考虑的特殊事项	

5.2.2 应用权限

表 4 应用权限行为要求

标准描述	应用权限行为要求
预置条件	/
是否实现自动化	/
是否实现云测	/

测试方法	举证或测试
判定标准	- 透明：应列举具体、明确的权限类型、功能用途，知会用户、获得用户同意授权。 - 关闭保护：禁止执行 Root 操作、关闭设备安全保护等。 - 恶意诱导：禁止诱导、欺骗、恐吓、威胁用户开启开发者选项、开启 USB 调试。 - 最小化：仅申请功能所需的最小范围的权限。 - 频繁弹窗：禁止在应用运行过程中，频繁弹窗提示用户开放已拒绝授予的权限。 - 敏感权限：遵守各国家地区的法律法规要求，敏感权限必须获得用户明示授权。安卓的敏感权限范围，可参见 GB/T41391-2022 的附录 D。 - 选择权：用户可以选择拒绝授予某个权限，仅影响与该权限关联的应用功能的使用，不影响该应用的其他功能。 - 辅助功能：应用使用辅助功能应获得用户同意并且明确告知用户应用使用辅助功能的目的，不得超出告知用户的使用范围或者进行自动安装、窃取用户隐私等行为。
需考虑的特殊事项	注：关于频繁的定义，可参见[7]的 3.2。

5.2.3 应用敏感操作

表 5 应用敏感操作行为要求

标准描述	应用敏感操作行为要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 特征：未经用户授权同意且未向用户明示，禁止收集用户设备、系统版本、已安装应用/软件列表、上网记录等相关基础特征信息。 - 配置：未经用户授权同意且未向用户明示，禁止应用修改系统相关配置、修改其他应用的配置、阻碍其他应用的正常运行。 - 位置：未经用户授权同意且未向用户明示，或用户未使用该应用时，禁止应用程序在后台持续获取定位信息。 - 通信：未经用户授权同意且未向用户明示，禁止应用读取通信录、短信、用户本机号码、电话本数据、通话记录，禁止应用直接进行拨打电话、发送短信。 - 监控：未经用户授权同意且未向用户明示，禁止应用直接进行截屏/录屏、读取相册、录音、摄像。 - 网络：未经用户授权同意且未向用户明示，禁止应用直接开启 WLAN、蓝牙、NFC。
需考虑的特殊事项	

5.2.4 应用流氓行为

表 6 应用流氓行为要求

标准描述	应用流氓行为要求
------	----------

预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 常驻后台：如果没有相关功能需求以及用户明确授权，应用不应常驻后台。 - 关联启动或自启动：如果没有合理功能需求以及用户明确授权同意，禁止应用通过后台关联启动或自启动，无法关闭。 - 消息常驻：如果没有相关功能需求以及用户明确授权，不推荐应用消息常驻通知栏、悬浮窗、锁屏页面、桌面。 - 恶意覆盖：如果没有相关功能需求以及用户明确授权，应用不应悬浮窗、弹窗覆盖其他应用的显示窗口、页面。 - 后台弹窗：如果没有相关功能需求，禁止应用在后台直接弹窗。 - 数据隔离：禁止应用读取、修改其他应用的内存数据。 - 应用卸载：禁止应用包含反卸载或假卸载操作。例如不应通过技术手段增加卸载难度；应提供彻底删除 App 专属存储目录下个人信息的机制。
需考虑的特殊事项	

六、应用开发安全技术要求

6.1 数据安全

6.1.1 机密性

表 7 数据安全的机密性要求

标准描述	数据安全机密性要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 密钥安全：应提供安全的密钥存储机制，防止密钥在没有授权的情况下被泄露、修改、替代或者删除。私钥的存储要求保证机密性与完整性；禁止硬编码私钥等敏感信息，防止攻击者反编译代码后泄露私钥。 - 访问控制：宜加密密钥数据库，避免在数据库中存储明文和敏感信息；涉及敏感信息需加密存储，且要有合适的加密强度，不应使用弱加密、不应采取明文形式存储或传输敏感信息。 - 算法要求：必须选用标准加解密算法，并选用安全加密模式。禁止使用私有密码算法、过时密码算法（如 RC4/DES/3DES 等）、算法的不安全模式（默认加密模式为 ECB，但 ECB 的安全性较弱，会使相同的明文在不同的时候产生相同的密文，容易遇到字典攻击），避免信息泄露。
需考虑的特殊事项	

6.1.2 完整性

表 8 数据安全的完整性要求

标准描述	数据安全完整性要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 沙箱管控：默认启用沙箱技术，限定私有数据访问。 - 访问控制：采用系统默认的授权机制请求数据。禁止通过 CNVD、CNNVD、CVE、CNCVE 等公开发布了 6 个月及以上的高危安全漏洞利用等越权行为访问或修改非本应用沙箱数据。 - 数据校验：通过 HMAC、签名值等方式校验传输数据完整性。
需考虑的特殊事项	

6.2 编码安全

6.2.1 编码规范

表 9 编码安全规范

标准描述	编码安全规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 数据检查：应用必须针对输入、输出数据进行异常检查，例如注意空值判定及类型转换判断，防止由于解析异常参数导致的应用崩溃（本地拒绝服务）。 - 开源合规：禁止使用存在 CNVD、CNNVD、CVE、CNCVE 等公开发布了 6 个月及以上的高危安全漏洞的旧版本开源软件、框架、函数库。 - 接口安全：不宜沿用安卓系统废弃接口。 - 禁止绕过：禁止通过提升权限等方式绕过系统推荐的标准权限申请、数据访问控制策略。 - 日志分级：应通过 Log Level 管控日志信息。 - 关闭调试：正式产品发布前应关闭调试，即 android:debuggable 属性设置为 false。 - TargetSDK：应用的 API Level 不能低于 30（即 TargetSdk Version 不能低于 30）。
需考虑的特殊事项	

6.2.2 审计加固

表 10 审计加固

标准描述	审计加固
预置条件	/

是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 代码审计：应用必须通过自动化、或人工的代码审计检查。 - 混淆：应用发布之前必须进行混淆。 - 加固：宜在应用发布之前进行 App 加固，降低对 App 反汇编分析等风险。
需考虑的特殊事项	

6.2.3 第三方 SDK 规范

表 11 第三方 SDK 规范

标准描述	第三方 SDK 规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- SDK 接入：至少应遵循 GB/T 35273-2020 的 7； - SDK 管控：禁止使用业界已披露存在风险的第三方 SDK，可参考[9]的 6.3。
需考虑的特殊事项	

6.2.4 应用权限规范

表 12 应用权限规范

标准描述	应用权限规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 权限最小化：仅申请功能所需的最小权限。 - 调试开关：默认关闭调试。 - 组件导出：除非功能需要，默认禁止组件导出。 - 数据传递：除非功能需要、并获得用户授权，否则禁止应用将从 A 应用获取的数据传递给 B 应用。 - 备份功能：除非功能需要，默认关闭备份功能，即 android:allowBackup 属性设置为 false。
需考虑的特殊事项	

6.2.5 组件安全规范

表 13 组件安全规范

标准描述	组件安全规范
预置条件	/
是否实现自动化	/
是否实现云测	/

测试方法	举证或测试
判定标准	- 组件调用：无需暴露的组件应该显式的将 <code>android:exported</code> 设置为 <code>false</code>。 - 组件权限：禁止内部组件被外部程序调用，如需被外部调用，应检查调用者是否符合访问控制机制。 - Intent 使用：禁止恶意构造篡改 Intent 参数，避免引发拒绝服务等风险。
需考虑的特殊事项	

6.2.6 工具链安全规范

表 14 工具链安全规范

标准描述	工具链安全规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 工具安全：禁止使用非官方渠道提供的开发、编译、发布工具。 - 环境安全：应确保应用开发环境的 IT 安全。 - 密钥安全：应确保后台应用签名密钥、应用加密密钥、证书对应的私钥等关键密钥数据安全。
需考虑的特殊事项	

6.3 业务安全

6.3.1 业务鉴权规范

表 15 业务鉴权规范

标准描述	业务鉴权规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 认证鉴权：应用或组件请求数据必须进行认证、鉴权。 - 设备特征：云端应结合终端设备特征进行风险判定。 - 第三方共享：与第三方共享数据，应通过 token 机制动态授权，云端管控。 - 多因子校验：对于敏感信息（例如支付、隐私信息）操作，应进行 PIN 码、短信、指纹、面部识别等多因子校验。 - 缓存凭据：除非相关法规标准允许、或者特殊业务场景下的安全例外，否则禁止在终端本地缓存业务核心凭据（例如认证码）。 - 安全输入：对安全要求较高的密码等敏感信息，应提供安全键盘作为数据输入接口。
需考虑的特殊事项	

6.3.2 安全策略规范

表 16 安全策略规范

标准描述	安全策略规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 时间戳：应用近场通信、或者本地鉴权应避免伪造时间戳攻击。 - 指令安全：应用近场或远程的指令交互，必须考虑防重放、绕过认证、水平攻击、垂直攻击的风险。 - 短信验证码：必须限制短信验证码的有效期。禁止多次失败后，自动绕过校验的后台逻辑错误。 - 劫持防范：必须进行证书校验，有条件时尽量进行证书状态检查，防范劫持攻击。
需考虑的特殊事项	

6.4 隐私保护规范

本标准遵守隐私法律法规，详细的隐私保护要求在《移动智能终端生态联盟标准 第6部分：个人信息保护技术要求》中定义。

表 17 隐私保护规范

标准描述	隐私保护规范
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 机密性：在数据传输期间对数据进行加密保护（例如 HTTPS），避免恶意劫持。支持 TLS1.2 及以上的版本。 - 数据泄露：禁止明文存储、明文传输、日志直接打印敏感信息、以及用户密码等风险信息。 - 数据处理：应根据隐私法律法规、以及联盟的隐私标准要求，对敏感信息进行匿名化、去标识化、加密等隐私保护处理，并对数据进行完整性保护，避免恶意篡改。 - 访问控制：在存储期限内对数据实施访问控制，避免未授权访问。 - 日志审计：在存储期限内记录访问数据的行为日志，支持审计。
需考虑的特殊事项	

七、应用内容安全要求

7.1 基本要求

GB/T37729-2019 的 4.1.2, 适用于应用内容的安全要求。同时, 应用内容安全应遵守现行法律规定及公序良俗的要求, 不得含有令人不快或具有攻击性的内容, 不会损坏用户设备, 不会在使用过程造成人身伤害, 包括但不限于下列要求:

- a) 不含政治内容;
- b) 不含暴恐血腥内容;
- c) 不含违禁品内容;
- d) 不含色情内容;
- e) 不含赌博或彩票类内容; 不含恶意扣费、欺诈内容;
- f) 广告不存在违反《中华人民共和国广告法》、《互联网广告管理暂行办法》等内容。

7.2 政治内容管理要求

表 18 应用政治内容要求

标准描述	政治内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	应用内容管理: 应用内禁止含有政治谣言、涉及反政府、反社会以及其他涉及政治敏感内容。 用户行为管理: App 禁止用户提交含有政治谣言、涉及反政府、反社会以及其他涉及政治敏感内容。
需考虑的特殊事项	

7.3 暴恐血腥内容管理要求

表 19 暴恐血腥内容管理要求

标准描述	暴恐血腥内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	- 应用内容管理: 应用内禁止含有恐怖、暴力、血腥元素相关内容, 包括但不限于人类或动物遭到杀害、残害、酷刑、虐待的写实描绘, 鼓吹暴力, 令人产生不适、恐惧的文字、图片、音频、视频内容等。在游戏中, “敌人” 不能单单针对特定种族、文化、真实存在的政府或企业, 或是任何其他真实存在的实体。 - 用户行为管理: 应用禁止允许用户提交含有恐怖、暴力、血腥元素相关内容的文字、图片、音频、视频内容等。
判定标准	举证或测试
需考虑的特殊事项	

7.4 违禁品内容管理要求

表 20 违禁品内容要求

标准描述	违禁品内容要求
预置条件	/

是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 应用内容管理：应用禁止含有不负责任地使用枪支弹药及相关器材、违禁品的描述，或促进枪支弹药及相关器材交易、违禁品交易的文字、图片、音频、视频内容等。 - 用户行为管理：应用禁止用户提交违禁物品交易或制作的文字、图片、视频、音频内容等。 - 销售：应用禁止含有枪支弹药及相关器材、违禁品交易功能。
需考虑的特殊事项	涉及法律法规可参考

7.5 宗教、种族等内容管理要求

表 21 宗教、种族内容管理要求

标准描述	宗教、种族内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 应用内容管理：应用禁止含有关于宗教、种族、性取向、性别或其他目标群体的诽谤或恶意内容等文字、图片、音频、视频等。 - 用户行为管理：应用禁止用户提交关于宗教、种族、性取向、性别或其他目标群体的诽谤或恶意内容的文字、图片、音频、视频等。
需考虑的特殊事项	

7.6 色情内容管理要求

表 22 色情内容管理要求

标准描述	色情内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 应用内容管理：应用禁止含有应用提供色情内容或色情服务等。（韦氏词典对“色情”一词的定义是：对性器官或性活动的露骨描述或展示，目的在于刺激性快感，而非带来美学价值或触发情感） - 用户行为管理：应用禁止允许用户提交色情或隐晦色情内容。
需考虑的特殊事项	

7.7 赌博、彩票类内容管理要求

表 23 赌博、彩票类内容管理要求

标准描述	赌博、彩票类内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/

测试方法	举证或测试
判定标准	- 应用内容管理：应用禁止含有线上违规销售彩票、赌球、赌马或进行棋牌游戏赌博等内容。 - 用户行为管理：应用禁止允许用户提交虚假彩票信息。
需考虑的特殊事项	体彩、福彩国家或地方官方推出的福利彩票类应用属于安全应用，例如“中国体育彩票”。

7.8 恶意扣费、欺诈内容管理要求

表 24 付费标准

标准描述	恶意扣费、欺诈内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	举证或测试
判定标准	- 应用付费标准：付费标准需要公开透明且必须在用户知情并同意的情况下进行扣费，禁止存在包括但不限于用户不知情或未授权的情况下，自动订购付费服务或无二次确认直接扣费等情况。 - 付费资质：(1) 应用程序内存在的付费项符合国家法律法规；(2) 特殊行业需要获得国家相关资质，不得无证经营，包括但不限于游戏行业需要获得《网络游戏出版物号（ISBN）》。 - 应用欺诈：(1) 应用不得存在欺骗性内容，诱导用户进行付费；(2) 用户付费后，用户需获得应有的付费服务。

7.9 广告内容管理要求

表 25 广告内容管理要求

标准描述	广告内容管理要求
预置条件	/
是否实现自动化	/
是否实现云测	/
测试方法	- 广告内容管理要求：(1) 广告内容不得存在违反《中华人民共和国广告法》、《互联网广告管理暂行办法》等内容，包括但不限于存在于政治谣言、涉及反政府、色情等；(2) 应用不得存在欺骗，诱导点击形式的低质量推广广告或广告内容含有虚假内容等；(3) 医疗、药品、特殊医学用途配方食品、医疗器械广告等法律、行政法规规定须经广告审查机关进行审查的特殊商品或者服务的广告，未经审查，不得发布，且互联网广告主应当对广告内容的真实性负责。 - 广告功能管理要求：(1) 应用内广告应当具有可识别性，显著标明“广告”或其他广告标识；(2) 应用内广告不得存在强制用户点击的情况，且必须含有显著的关闭按钮；(3) 应用不得强制推送通知栏广告；(4) 应用内广告不得频繁弹出影响用户体验。
判定标准	
需考虑的特殊事项	

参考文献

- [1]GB/T 32927—2016 信息安全技术移动智能终端安全架构.
- [2]GB/T 35278—2017 信息安全技术移动终端安全保护技术要求.
- [3]TAF-WG4-AS0015 移动智能终端安全能力技术要求.
- [4]GB/T 30284—2020 信息安全技术移动通信智能终端操作系统安全技术要求(EAL 2 级).
- [5]GB/T 34976—2017 信息安全技术移动智能终端操作系统安全技术要求和测试评价方法.
- [6]GB/T 34978—2017 信息安全技术移动智能终端个人信息保护技术要求.
- [7]TC260-PG-20202A 网络安全标准实践指南—移动互联网应用程序(App)收集使用个人信息自评估指南.
- [8]TC260-PG-20204A 网络安全标准实践指南——移动互联网应用程序(App)系统权限申请使用指引(征求意见稿).
- [9]信息安全技术移动互联网应用程序(APP) SDK 安全指南.